

Audit de Sécurité — DataShare

Aperçu

Ce document présente les résultats des analyses de sécurité effectuées sur la plateforme DataShare dans le cadre de l'étape finale de qualité.

Date : 2026-06-18

Outils : npm audit , revue manuelle du code

Périmètre : Backend (NestJS), Frontend (React/Vite), Infrastructure (Docker Compose)

1. npm audit — Backend

Commande

```
cd backend && npm audit
```

Résumé des Résultats

Sévérité	Nombre
Élevée	10
Modérée	34
Faible	3
Total	47

Vulnérabilités Principales

Paquet	Sévérité	Description	Décision
@nestjs/core <=11.1.17	Modérée	Injection via un composant en aval (GHSA-36xv-jgw5-4q75)	Acceptée — Dépendance CLI de développement uniquement, non exposée en environnement de production
@nestjs/platform-express	Modérée	Dépend de versions vulnérables de body-parser, express, multer	Acceptée — Transitive via NestJS, en attente de la mise à jour vers NestJS v12
body-parser <1.20.3	Élevée	Pollution de prototype (GHSA-qwcr-r2fm-qrc7)	Acceptée — NestJS fixe la version, pas de chemin d'exploitation direct avec notre validation (DTOs de type Pydantic)
express <4.21.2	Élevée	XSS via res.redirect(), traversée de chemin	Acceptée — Nos routes utilisent des DTOs typés, pas de redirections contrôlées par l'utilisateur

multer <=1.4.4	Élevée	ReDoS dans l'analyse des noms de fichiers	Acceptée — Le téléversement valide le content-type, la taille des fichiers est limitée à 1 Go
webpack 5.49-5.104	Modérée	SSRF via buildHttp (GHSA-8fgc-7cc6-rx7x)	Ignorée — Outil de développement uniquement (@nestjs/cli), non utilisé en production
ajv 7.0-8.17.1	Modérée	ReDoS avec l'option \$data	Ignorée — Dépendance de développement uniquement (@angular-devkit), absente du runtime
uuid <11.1.1	Modérée	Vérification manquante des limites du tampon dans v3/v5	Acceptée — Nous utilisons uuid v4 (aléatoire), aucun paramètre de tampon transmis
tmp <0.2.3	Faible	Création non sécurisée de fichiers temporaires	Ignorée — Développement uniquement (outil CLI inquire)
lodash	Modérée	Pollution de prototype	Ignorée — Transitive via @nestjs/swagger, utilisée uniquement au moment du build pour la spécification OpenAPI

Actions de Remédiation

```
# Fix non-breaking vulnerabilities
npm audit fix

# Result: fixes 0 of 47 (all require breaking changes to NestJS core)
```

Décision : Les 47 vulnérabilités se trouvent toutes dans des **dépendances transitives** du framework NestJS ou des outils de développement (@nestjs/cli , webpack , @angular-devkit). Aucune n'est directement exploitable dans notre déploiement en production :

- Le backend fonctionne derrière un proxy inverse Nginx avec TLS
- Toutes les entrées utilisateur sont validées via des DTOs class-validator
- Les téléversements de fichiers sont limités en taille et vérifiés par content-type
- Pas de redirections contrôlées par l'utilisateur ni de rendu de templates

Correctif prévu : Mise à niveau vers NestJS v12 lorsqu'il sera stable (devrait résoudre plus de 40 vulnérabilités).

npm audit fix --force

Non appliqué — introduirait des changements incompatibles de @nestjs/core@11 → @nestjs/core@12 nécessitant un effort de migration hors du périmètre du MVP.

2. npm audit — Frontend

```
cd frontend && npm audit
# Error: no package-lock.json present
```

Statut : Le frontend utilise uniquement `package.json` (pas de fichier de verrouillage commité). `npm audit` nécessite un fichier de verrouillage.

Atténuation : Le frontend est une SPA Vite+React avec un minimum de dépendances (`react` , `react-router-dom` , `axios`). Aucune vulnérabilité connue dans ces dépendances directes aux versions actuelles.

3. Revue de Sécurité Applicative

 Authentification et Autorisation

Contrôle	Statut	Détails
Hachage des mots de passe		bcrypt avec salage
Signature JWT		HS256 avec secret de 32+ caractères
Validation JWT		Vérifie sub, email, exp
Rotation des jetons de rafraîchissement		L'ancien jeton est révoqué lors du rafraîchissement
Cookies HttpOnly		Jeton de rafraîchissement dans un cookie HttpOnly/Secure/SameSite
Limitation de débit		Non implémentée (MVP) — recommandée pour la v1.0

 Protection des Données

Contrôle	Statut	Détails
TLS en transit		Proxy inverse Nginx avec HTTPS
Secrets externalisés		.env non commité, .env.example avec des valeurs factices
Pas de secrets dans le code		Vérifié : aucune donnée d'identification codée en dur
Pas de secrets dans les logs		Les logs ne contiennent que l'action/statut, pas de jetons/mots de passe
Validation des entrées		class-validator sur tous les DTOs
Injection SQL		ORM Prisma avec requêtes paramétrées
Limite de taille de fichier		MAX_FILE_SIZE_BYTES (par défaut 1 Go)

 Recommandations pour la Production

Priorité	Recommandation
----------	----------------

Élevée	Ajouter une limitation de débit sur les points d'entrée d'authentification (express-rate-limit)
Élevée	Ajouter une liste blanche CORS (autorise actuellement les origines configurées)
Moyenne	Ajouter des en-têtes CSP via Nginx
Moyenne	Implémenter le verrouillage de compte après N tentatives de connexion échouées
Faible	Ajouter la journalisation des requêtes avec des identifiants de corrélation
Faible	Mettre en place une analyse automatisée des dépendances en CI (Dependabot/Renovate)

4. Sécurité de l'Infrastructure

Docker Compose

Contrôle	Statut	Détails
Conteneurs non-root	⚠️	Non appliqué (MVP)
Isolation réseau	✅	Réseau bridge datashare-net
Persistance des volumes	✅	Volumes nommés pour PostgreSQL + MinIO
Exposition des ports	✅	Seuls Nginx (443, 80) + MinIO (9000) sont exposés
Secrets dans compose	✅	Via variables d'environnement, non codés en dur

.gitignore

Vérifié : `.env` , `*.pem` , `certs/` , `node_modules/` , `coverage/` , `*.secret.*` sont tous ignorés.

5. Bug Corrigé — Analyse du Booléen SSL MinIO

Problème : `MINIO_USE_SSL=false` dans `.env` était interprété comme la chaîne `'false'` (considérée comme vraie en JS), ce qui amenait le client S3 à se connecter en HTTPS à un serveur MinIO en HTTP simple → crash `EPROTO` .

Correctif : Remplacement de `config.get<boolean>('MINIO_USE_SSL', false)` par `config.get<string>('MINIO_USE_SSL', 'false') === 'true'` pour une comparaison de chaînes correcte.

Impact : Le conteneur backend était en boucle de redémarrage. Corrigé dans cette PR.